Security and Usability Trade-offs

WM241-18
Human Behaviour in Cyber Systems
5655691

Section 1 - Model Usage Scenario:

The usage scenario describes using Samsung Pass on a primary device with the intention of saving credentials when creating an account. A prompt appears after details have been input into the login fields, and users are met with biometric authentication after choosing to use the system to store their information. After entering the same login page on their synced secondary device, the autofill option will be available for use. A list will be provided, allowing selection of their desired email, where the fields are automatically populated and users automatically logged in.

However, this seemingly seamless scenario contains several aspects of difficulty-of-use that create risks to security. Firstly, system-initiated interruptions caused by the pop-up interrupts workflow, disrupting login tasks [1]. This directly relates to the Kainda model factor of efficiency, stating “while users may use a system to achieve a specific goal, achievement in itself is not sufficient”, as the prompt consumes time to read and disrupts workflow [5].The frustration from this affects satisfaction, with users experiencing friction whenever it appears and immediately dismissing it as a result. This can potentially lead to the negative conditioning of users by eroding vigilance and developing warning fatigue, leaving them vulnerable and dismissive of future security threats [2; 5].

Further fatigue is observed within the scenario, due to the repetitiveness and inconvenience of authentication. Combined with the cognitive load required to make a security decision to create and save strong credentials, users may feel a lack of motivation to engage in secure practices and avoid using the system altogether, affecting effectiveness from the Kainda model due to potential abandonment of the service [5]. Furthermore, knowledge/skill is required for the scenario, as critical features such as syncing data are usually only found upon failure, being a hidden dependency that requires enabling beforehand. This again affects effectiveness due to users falling back on insecure security practices such as password re-use, and the lack of transparency undermines the system’s perceived reliability to further amplify the negative conditioning of Samsung Pass.

Section 2 - Model Threat Scenario:

The threat scenario details the risk of credential compromise through the negative conditioning established in users [5]. This leads to insecure password practices, due to frustrating initial interactions with Samsung Pass which discourages them from using the system subsequently. When signing into their accounts during device setup, they are faced with the important decision about attempting to use Samsung Pass again, which has been associated with negative attributes such as hindrance, or stick to the cognitively easier method of reusing or creating easy to guess passwords.

The combination of a negatively perceived system and insecure practice accentuates the idea that the threat scenario has high easiness-of-use. This occurs because the cognitive default is to re-use passwords, with users following the path of least resistance to complete their task [3; 4]. Their primary motivator is the convenience of using a familiar, memorable password, whereas Samsung Pass requires decision making and learning of the application [4]. This stems from negative conditioning from previous initial experiences, combined with eroded motivation due to the cognitive difficulty in a change of habitual neural pathway routine and practiced motor memory. This highlights multiple Kainda factor failures,

with negative conditioning and motivation leading to the collapse of the system's effectiveness, as it stops being utilised by the user, going against the idea that "a system is only useful if its users are able to achieve intended goals" [5]. Simultaneously, the knowledge/skill for manual password management remains the dominant and easier mental model, as learning how Samsung Pass functions comes at greater mental strain.

Section 3 - Recommendations:

Two high-risk issues requiring immediate attention have been prioritised using the risk matrix (see Appendix A) and assessed in Appendix B: "Unreliable prompts" - a high-risk de-motivator with a risk score of 100, and the system being "Tied to the Samsung Ecosystem" - a high-risk motivator for risky behaviour also scoring 100. The scoring is based on a likelihood-impact matrix adapted from MIST SP 800-30 [6]. The following recommendations aim to reshape Samsung Pass from a potential obstacle to secure behaviour into a reliable and more accessible security tool that supports user workflows.

Commonly used websites such as Spotify and Reddit have been reported to have inconsistencies with the system, with users claiming that the saving credentials prompt does not appear. The first recommendation implements continuous automated testing and investment into development to detect login forms, in order to fix detection failures and support more websites. This improves performance reliability, enhancing the Kainda factor of effectiveness [5]. In addition, a feature introducing a user-initiated option to "save details" could be added in a non-obtrusive way near the virtual keyboard. This solves the issue of manual workarounds by making it more accessible for the user, removing the inefficiency demotivator and preventing negative conditioning due to higher convenience, reduced time consumption and greater appeal to the user. Despite increased short-term complexity, it directly mitigates the high risk of the password manager abandonment and encourages long term secure practices.

Users who own devices outside the Samsung ecosystem face the dilemma of Samsung Pass not being readily available on these devices, despite potentially wanting to use it. The second recommendation involves creating a browser extension that requires authentication from the device so that the system is more easily accessible on computers, synced with Samsung accounts. This would allow users to seamlessly transfer credentials used on one device to another, for universal accessibility, countering the motivation for insecure workarounds and improving effectiveness for cross-device workflows [5].

However, this would increase the attack surface of the system, since the device's password/pin can be used to access the manager, as opposed to biometric authentication. While this is a trade-off, it is acceptable because it removes the primary motivator for insecure practices of password re-use, facilitating the creation of stronger passwords and encouraging saving to Samsung Pass.

By implementing these two recommendations, the highest risk issues as defined in the risk matrix are addressed, and while in the short run they have significantly increased development costs and system complexity, it enables long-term security by changing the "path of least resistance" from re-using unsafe passwords to using the password manager due to greater accessibility [2]. This aligns usability with security, countering the key motivators and de-motivators previously mentioned.

References:

[1] Adams, A. and Sasse, M.A. (1999) 'Users are not the enemy', Communications of the ACM, 42(12), pp. 40–46

[2] Beautement, A., Sasse, M.A. and Wonham, M. (2009) 'The compliance budget: Managing security behaviour in organisations', Proceedings of the 2008 New Security Paradigms Workshop, pp. 47–58

[3] Florencio, D. and Herley, C. (2007) 'A large-scale study of web password habits', Proceedings of the 16th International Conference on World Wide Web (WWW 2007), pp. 657–666

[4] Inglesant, P. and Sasse, M.A. (2010) 'The true cost of unusable password policies: Password use in the wild', Proceedings of the SIGCHI Conference on Human Factors in Computing Systems (CHI 2010). New York: ACM, pp. 383–392

[5] Kainda, R., Flechais, I. and Roscoe, A.W. (2010) 'Security and usability: Analysis and evaluation', *Proceedings of the 5th International Conference on Availability, Reliability and Security (ARES 2010)*. Los Alamitos, CA: IEEE Computer Society, pp. 275–282

[6] Stoneburner, G., Goguen, A. and Feringa, A. (2002) Risk Management Guide for Information Technology Systems (NIST Special Publication 800-30). Gaithersburg, MD: National Institute of Standards and Technology

Appendix:

Appendix A:

Threat Likelihood	Impact		
	Low (10)	***Medium*** (50)	***High*** (100)
High (1.0)	**Low** 10 X 1.0 = 10	**Medium** 50 X 1.0 = 50	**High** 100 X 1.0 = 100
Medium (0.5)	**Low** 10 X 0.5 = 5	**Medium** 50 X 0.5 = 25	**Medium** 100 X 0.5 = 50
Low (0.1)	**Low** 10 X 0.1 = 1	**Low** 50 X 0.1 = 5	**Low** 100 X 0.1 = 10

Risk Scale: High (>50 to 100); Medium (>10 to 50); Low (1 to 10)[8]

Risk matrix adapted from NIST SP 800-30 (Stoneburner et al., 2002)

Appendix B:

Issue	Motivator/De-motivator	Likelihood rating	Impact rating	Risk Level
Unreliable prompts	De-motivator - Becomes untrustworthy	High (1)- common reported problem	High (100)- Leads to abandonment of system	High (100)
Tied to Samsung ecosystem	Motivator - Encourages risky behaviour	High (1)- Most do not solely use Samsung	High (100)- Encourages re-using passwords	High (100)
Obtrusive pop-up	De-motivator - Negative user experience	High (1)- Everytime there is new login	Medium (50)- Useful for many people	Medium (50)
Manual workaround	De-motivator - Inefficient process	High (1)- Needed when prompts do not appear	Medium (50)- System works other times	Medium (50)
Biometric failure (without backup login)	De-motivator - Prevents use of system	Medium (0.5)- not everyone sets up backup	High (100)- May block all access	Medium (50)